

RIPHAH INTERNATIONAL UNIVERSITY



Faculty of Computing | I-14 Campus, Islamabad
FINAL YEAR PROJECT PROPOSAL & PLAN

SPINE

**SPINE: A Cyber Investigation State Model for AI-Assisted
Cyber Incident Investigation in Security Operations Centers**

Project Team

Full Name of Student	SAP Id	Program	Contact Number	Email Address
Muhammad Ahsan Qureshi	55704	BSCY	03420786006	55704@students.riphh.edu.pk
Mubashir Ahmed	55214	BSCY	03125948908	55214@students.riphh.edu.pk

Syed Yawar Abbas
(Lecturer)

Change Record

Author(s)	Version	Date	Notes	Supervisor's Signature
Ahsan Qureshi / Mubashir Ahmed	1.0	2026-08-30	Original project draft	
Ahsan Qureshi / Mubashir Ahmed	2.0	2026-09-10	Updated after scope refinement and supervisor discussion	
Ahsan Qureshi / Mubashir Ahmed	3.0	2026-09-23	Updated after faculty panel recommendations and supervisor discussion: Qwen2.5-7B selection and integration, practical resource assessment, Wazuh-based threat-priority normalization, commercial market survey, hybrid alert association, and AI evaluation/evidence justification.	

Project Proposal

Project Title: SPINE A Cyber Investigation State Model for AI-Assisted Cyber Incident Investigation in Security Operations Centers

Executive Summary

This proposal presents SPINE, an AI-assisted investigation-state framework for a single analyst working in a controlled Windows enterprise LAN laboratory. The project addresses the loss of investigative context when related Wazuh alerts, Sysmon endpoint events, and Suricata network events are examined separately. SPINE will associate alerts with investigation cases and retain questions, evidence, entities, events, findings, contradictions, unresolved information, and history as a case develops. A local language model will assist with evidence interpretation and traceable findings, while predefined checks assess investigation sufficiency and the analyst remains responsible for validation and case closure. The prototype will be evaluated through four reproducible scenarios: suspicious PowerShell execution, brute force followed by a successful login, rogue service persistence, and anomalous DNS activity. Evaluation will examine alert association, evidence coverage, question resolution, traceability, AI grounding, latency, and resource use. Autonomous containment and production-scale deployment are outside the project scope.

1. Opportunity & Stakeholders

Security Operations Centers (SOCs) rely on security monitoring systems to identify potentially malicious activity across organizational systems and networks. These systems generate alerts from endpoint, network, and other telemetry sources. However, an individual alert rarely provides a complete understanding of an incident. Analysts must identify relevant entities and events, collect evidence, establish relationships between observations, reconstruct activity, and determine whether the available information is sufficient to support an investigation outcome. The intended user is a SOC analyst who needs to review why alerts were associated, inspect supporting evidence, and decide whether an investigation can be closed.

The problem becomes more difficult when relevant observations are distributed across multiple alerts and telemetry sources. Suspicious process execution, file activity, and network communication may appear as separate alerts even though they represent different stages of the same security incident. If each alert is investigated independently, relationships between them may be lost and analysts may repeat evidence searches or manually reconstruct the broader incident.

The proposed project focuses on maintaining the investigation itself as a persistent computational state. Instead of treating each alert as an isolated investigation, related

alerts can extend an existing investigation case while previously acquired evidence, questions, findings, and relationships remain available.

The proposed framework, SPINE, will operate as a post-alert investigation and decision-support layer using Wazuh as the central alert source [1], Sysmon for Windows endpoint telemetry [2], and Suricata for network telemetry [3].

2. Problem Statement

Security alerts do not necessarily represent independent incidents. Multiple alerts may describe different observations, actions, or stages of the same underlying security activity.

When related alerts are investigated independently:

- Investigation context may become fragmented
- Relationships between alerts, evidence, entities, and events may not be maintained
- Analysts may repeat investigation steps
- Previously collected evidence may not be reused effectively
- The complete incident may require manual reconstruction

At the same time, alerts occurring close together are not necessarily related. Incorrectly combining independent activity may introduce misleading evidence and produce inaccurate investigation outcomes.

Existing AI-assisted security systems can support alert analysis, evidence retrieval, summarization, reasoning, correlation, and case management. The problem addressed by this project is therefore not simply detecting or correlating alerts, but maintaining the evolving investigation context after related alerts have been identified.

The central problem is:

How can related security alerts be associated with and maintained within a persistent investigation state so that accumulated questions, evidence, relationships, findings, and investigation history continue to support subsequent investigation steps?

3. Literature Review

3.1 AI-Assisted Security Investigation

Recent research demonstrates that AI and multi-agent systems can support SOC activities such as alert triage, evidence analysis, information retrieval, and investigation reasoning.

ALUSKORT presents a post-SIEM, multi-agent investigation workflow and reports a best IOC-extraction F1-score of 0.864 [4]. Its evaluation used four Wazuh alerts and a limited toolset; the reported score measures IOC extraction rather than overall investigation correctness, and the study did not measure full end-to-end tool latency.

CORTEX uses collaborative LLM agents for evidence-grounded alert triage and reports actionable-alert F1 of 0.78 and a false-positive rate of 14.2%, compared with 0.66 and 24.9% for its tool-using baseline [5]. Its per-alert context does not persist across alerts. The evaluation covers ten-plus scenarios, and its reported median latency of 152.4 seconds and high token use show a cost and latency trade-off; the authors also identify upstream telemetry quality and distribution shift as limitations.

AgCyRAG combines agentic reasoning with knowledge-graph and vector retrieval for security analysis [6]. The paper demonstrates three analytical scenarios, but its graph access is bounded by predefined queries and it does not evaluate long-running, multi-alert case state. The authors note remaining hallucination and adversarial risks and call for broader evaluations.

Together, these studies show that AI can assist with alert analysis and evidence retrieval, while their reported measures and evaluation settings differ. Their results should not be read as directly comparable measures of end-to-end SOC investigation quality.

3.2 Alert Correlation and Multi-Alert Investigation

Alert aggregation and correlation are established research areas. Landauer et al. evaluate domain-independent alert grouping and report substantial alert-group reduction [7]; these results concern aggregation and detection performance, not investigation-question resolution. Ban et al. report strong filtering performance and reduced alert volume on enterprise data [8], but their escalation labels depend on one organization’s appliances and analyst decisions, and the authors caution that reducing false positives can increase false negatives. AutoFlow studies alert sense-making and narrative construction using intrusion-detection datasets [9]; its results vary with dataset noise and cluster size, and it is a master’s thesis rather than a large operational SOC evaluation.

These studies show that alerts can be grouped and filtered, but their outcomes measure alert reduction, classification, or narrative support. Those outcomes do not establish that a system maintains investigation questions, evidence, and analyst decisions as a case evolves.

Instead, alert association is treated as the point at which an investigation case is created or extended.

3.3 Knowledge Representation

Cybersecurity knowledge graphs represent entities, events, relationships, and provenance. Jia et al. study knowledge-graph construction from cybersecurity information [10]; their

extraction results measure graph construction quality rather than investigation completeness. KRYSTAL uses graph-based provenance to discover attack activity in audit data [12], but its focus is attack discovery and event reconstruction rather than the analyst’s evolving questions and decisions. Sikos provides a survey of cybersecurity knowledge graphs [11], which offers conceptual coverage rather than an experimental evaluation of case-level investigation state.

KRYSTAL shows that graph-based representations can support efficient attack discovery and reconstruction [12].

These approaches provide useful foundations for structured evidence representation. However, representing cybersecurity facts is different from representing the state of an investigation. The proposed Cyber Investigation State also maintains investigative questions, findings, unresolved information, history, and sufficiency.

3.4 SOC Investigation and Human-Centred Decision Support

The proposed workflow draws on the iterative sensemaking process described by Pirolli and Card [13]. Their work concerns intelligence analysis and informs the design concept; it is not direct experimental evidence from a cybersecurity SOC. SOC research surveys identify workload and information-complexity challenges [14], [15]. Tilbury and Flowerday review human-automation issues in SOCs and discuss risks such as over-reliance and automation bias, while noting limits in their review search and selection process [16]. These sources support keeping analyst review and validation in the proposed workflow.

The proposed framework therefore follows a human-in-the-loop approach. AI-generated findings will support investigation but will not independently replace analyst judgment.

3.5 Comparative Analysis of Research

Table 1: Comparative Analysis Table

Research	Main Focus	Reported Evidence	Persistent Cross-Alert Investigation State
ALUSKORT [4]	Post-SIEM multi-agent investigation	IOC extraction F1 0.864 on a four-alert Wazuh pilot	Not demonstrated
CORTEX [5]	Collaborative LLM alert triage	Actionable F1 0.78; FPR 14.2%; median latency 152.4 s	Per-alert context; cross-alert state disabled
AgCyRAG [6]	Agentic knowledge-graph RAG analysis	Three analytical scenarios	Not a case-lifecycle evaluation
KRYSTAL [12]	Graph-based attack discovery	DARPA audit-data experiments; graph compression and reconstruction	Not demonstrated
Landauer et	Domain-independent	57,766 alerts; six attack steps;	Not demonstrated

Research	Main Focus	Reported Evidence	Persistent Cross-Alert Investigation State
al. [7]	alert aggregation	grouping and detection measures	
Ban et al. [8]	AI-assisted alert filtering and segmentation	Enterprise case study; filtering and reduction measures	Not demonstrated
AutoFlow [9]	Alert sense-making and narrative construction	CIC-IDS 2017/2018 evaluation; results vary with dataset noise	Not the primary focus
Proposed FYP	Persistent multi-alert investigation state	Four controlled scenarios; measures defined in Section 10	Planned

Existing research is therefore strong in individual capabilities such as AI reasoning, alert correlation, knowledge representation, and alert reduction. The proposed contribution lies in maintaining the investigation itself as the persistent object connecting related alerts, evidence, questions, findings, and investigation progress.

3.6 Existing Systems and Market Comparison

Commercial and open-source SOC platforms already provide extensive capabilities for detection, investigation, search, correlation, visualization, case management, and response.

Vectra AI provides AI-assisted threat detection, prioritization, and investigation [17]. Security Onion supports monitoring, hunting, and case management [18]. TheHive supports case-centered incident investigation and collaboration [19].

These systems demonstrate that the proposed project should not be positioned as a replacement for mature SOC platforms. Instead, the project investigates a narrower research problem: persistent, question-driven management of investigation state across related alerts.

Table 2: Commercial Systems

System	Primary Capability
Vectra AI [17]	AI-assisted threat detection and investigation
Splunk Enterprise Security [20]	SIEM, detection, correlation and analytics
IBM QRadar [21]	SIEM, alerting and offense management
Microsoft Sentinel [22]	Cloud-native SIEM/SOAR and investigation
Cortex XSOAR [23]	SOAR, playbooks and case management
Rapid7 InsightIDR / Incident Command [24]	SIEM and investigation
FortiSIEM [25]	Event correlation and incident management

Table 3: Open-Source and Community SOC Comparison

Capability	SPINE	AiSOC [26]	Vigil [27]	AI-SOC [28]	Talon [29]	Security Onion [18]	TheHive [19]
Case-specific evidence gathering	P	S	S	R	S	R	S
Alert-to-case association	P	S	R	R	R	A	S
Association rationale retained	P	S	ND	ND	ND	R	R
Persistent structured investigation state	P	R	R	R	R	R	R
Investigation-question tracking	P	ND	ND	ND	ND	ND	R
Negative evidence tracking	P	ND	ND	ND	ND	ND	ND
Investigation sufficiency assessment	P	ND	ND	ND	ND	ND	ND
Case reactivation and reassessment	P	ND	ND	ND	R	R	R

P = Planned; S = Supported in documentation; R = Related or partial functionality; A = Analyst-led; ND = Not demonstrated in reviewed documentation, not proven absent. Planned features are not demonstrated results. This documentation review is not a benchmark or a claim of overall superiority. TheHive is a community-accessible comparator; licensing varies by version and edition.

3.7 Research Gap

The literature establishes that:

- AI can support security investigation and reasoning
- Alert-correlation systems can identify related security activity
- Knowledge graphs can represent entities and relationships
- Mature SOC systems already provide substantial investigation capabilities

The less-developed problem concerns what happens after alerts are identified as related.

Across the reviewed work, alert correlation, AI-assisted analysis, knowledge representation, and commercial case management are established capabilities. The narrower gap addressed here is whether a bounded prototype can preserve and update an explicit investigation state across related alerts, including question status, evidence links, contradictions, unresolved information, and history.

The central research gap is therefore:

How can related security alerts be maintained within a persistent investigation state so that their accumulated context continues to guide evidence-grounded investigation over time?

4. Research Questions

RQ1: How can an investigation-state model represent and maintain evolving context across multiple related security alerts?

RQ2: How can a bounded alert-to-case association mechanism distinguish related from unrelated alerts while retaining an interpretable rationale?

RQ3: How effectively does the prototype maintain evidence coverage, question status, and investigation traceability across the four controlled scenarios?

RQ4: How effectively can local AI-assisted reasoning use the investigation context to produce evidence-grounded findings for analyst review?

5. Project Objectives

The project aims to:

1. Design and implement a Cyber Investigation State Model for persistent multi-alert investigation
2. Develop an explainable alert-to-case association mechanism for maintaining appropriate investigation boundaries
3. Maintain alerts, questions, evidence, entities, events, findings, unresolved information, relationships, and investigation history within a persistent case state
4. Integrate AI-assisted evidence analysis and reasoning through a bounded investigation workflow
5. Provide an analyst-facing interface and structured investigation report with evidence traceability
6. Evaluate alert association, investigation-state updates, evidence coverage, question resolution, traceability, AI grounding, latency, and resource use across the four controlled scenarios

6. Scope of the Project

The project will be implemented as a controlled laboratory prototype for Windows endpoints on a single enterprise LAN, using one Wazuh server and one SOC analyst persona. It will support post-alert investigation and will not claim production-scale SOC performance.

6.1 Security Monitoring and Telemetry

The system will use:

- **Wazuh as the central security monitoring and alert source**
- **Sysmon for Windows endpoint telemetry**
- **Suricata for network security telemetry**

An ingestion and normalization layer will transform relevant records into a consistent investigation representation.

6.2 Alert-to-Case Association

When a new alert is received, the system will evaluate its contextual relationships with existing investigation cases.

Relevant information may include:

- Host
- User
- Process
- File
- IP address
- Network endpoint
- Timestamp
- Alert characteristics
- Existing relationships within the investigation state

Following faculty feedback, the project will use a hybrid alert-association approach that combines contextual rules with an association method selected during implementation. The proposal fixes the required behavior and evaluation criteria while leaving the specific algorithm and configuration open.

The association mechanism will be assessed on whether it can:

1. Distinguish related from unrelated alerts
2. Maintain bounded and explainable association decisions
3. Preserve the basis of the decision for analyst review

Temporal proximity alone will not be sufficient to establish association.

6.3 Cyber Investigation State

Each case will maintain the information needed to continue and review an investigation:

- Associated alerts

- Association context
- Investigative questions
- Question status
- Evidence
- Entities and events
- Relationships
- Findings
- Contradictions
- Unresolved information
- Negative evidence
- Investigation history
- State transitions
- Sufficiency status

This allows information obtained earlier in the investigation to remain available when later related alerts arrive.

6.4 Investigation Priority

The original Wazuh rule level (0–16) will be preserved [1]. The faculty-approved project priority bands are Low (1–5), Medium (6–11), High (12–14), and Critical (15–16); level 0 is excluded from actionable prioritization. These project-defined bands support analyst attention and do not represent AI confidence or establish incident association.

6.5 AI-Assisted Investigation

AI will support:

- Evidence interpretation
- Relationship analysis
- Investigation-question handling
- Evidence-grounded finding generation
- Identification of unresolved or contradictory information

The workflow will use bounded AI components operating through the shared investigation state.

AI output will not independently:

- Determine final incident status
- Close an investigation
- Authorize destructive response
- Replace analyst validation

6.6 Investigation Scenarios

Evaluation will use four controlled, reproducible scenarios covering endpoint and network telemetry:

- 1. Suspicious PowerShell execution with relevant process context**
- 2. Repeated failed logins followed by a successful login**
- 3. Rogue service installation from a user-writable location**
- 4. Anomalous DNS activity observed in network telemetry**

The scenarios will be designed around telemetry that can be reliably generated and reproduced in the laboratory environment.

6.7 Exclusions

The project excludes:

- Unrestricted enterprise-scale alert clustering
- Production SOC deployment
- Support for every SIEM, EDR, operating system, or cloud platform
- Unrestricted autonomous response
- Destructive remediation
- Replacement of human analysts
- Claims of enterprise-scale operational performance

7. Proposed Methodology

7.1 Overall Investigation Workflow

The workflow begins when normalized telemetry reaches the alert-association component. The component creates a case or links an alert to an existing case with a recorded rationale. Evidence acquisition and analysis update the case state; unresolved or contradictory results can reopen questions and prompt additional evidence searches. A later related alert can reactivate a case. The analyst reviews the resulting evidence and findings before closure.

Security telemetry and alerts → ingestion and normalization → alert-to-case association → new or existing case → persistent investigation state → questions and evidence acquisition → evidence analysis → state update and sufficiency assessment → investigation output → analyst review

The important design principle is that investigation context is preserved and reused rather than reconstructed independently for every alert.

7.2 Ingestion and Normalization

Incoming telemetry will be parsed and transformed into a common representation.

The layer may perform:

- Parsing
- Normalization
- Deduplication
- Enrichment
- Extraction of investigation-relevant attributes

This allows downstream components to use a consistent representation. Deduplication will remove repeated ingestion of the same record while retaining occurrence counts, timestamps, and distinct repeated events needed to investigate activity bursts.

7.3 Alert-to-Case Association

The association component will compare incoming alerts with existing case context using contextual rules and an association algorithm. The specific technique may evolve during implementation based on effectiveness, explainability, and performance.

Regardless of the final implementation, the mechanism must:

- Use meaningful contextual relationships
- Avoid relying on time alone
- Distinguish related and unrelated activity
- Preserve the reason for an association decision
- Be evaluated against predefined ground truth

This keeps the research objective stable while allowing implementation optimization.

7.4 Investigation Manager

The Investigation Manager will handle:

- Creation of investigation cases
- Addition of related alerts
- Case routing
- Investigation lifecycle
- State updates
- Case reactivation when new related activity appears

7.5 Cyber Investigation State

The Cyber Investigation State is the central component of the framework.

It connects:

Alerts → Questions → Evidence → Entities and Events → Relationships → Findings → History → Sufficiency

When a related alert or new evidence arrives, the case state is updated and its history is retained. Evidence may resolve a question; contradictory evidence may reopen it; and missing telemetry is recorded separately from a negative result. Sufficiency indicates whether predefined scenario requirements are addressed. It does not determine that activity is malicious or close the case; the analyst makes the final decision.

7.6 Investigation Questions and Evidence

Investigation questions will be derived from alert characteristics, investigation requirements, existing state, and unresolved information. The framework will avoid unrestricted question generation. Question handling will remain bounded by defined investigation requirements and the evidence available within the project scenarios.

Questions will guide evidence acquisition.

Evidence will be linked to:

- Relevant questions
- Alerts
- Entities
- Events
- Findings

Evidence is linked to the question, alert, entity, event, and finding it supports. Negative evidence records that an expected observation was not found within a defined query scope and time window; unavailable telemetry is recorded as missing evidence.

7.7 AI-Assisted Reasoning

AI-assisted reasoning will operate on the structured investigation state and supporting evidence rather than on isolated alert text.

The workflow may divide reasoning into specialized functions such as:

- Evidence analysis and correlation
- Reasoning and finding generation

The exact internal orchestration may be refined during implementation for efficiency.

The architectural requirement is that AI reasoning receives the shared investigation context and produces evidence-linked outputs.

7.8 Investigation Sufficiency

The framework will assess investigation sufficiency against requirements defined for each scenario. The assessment will consider required questions and evidence, unresolved information, contradictions, and relevant relationships. It will support analyst review and will not automatically label an incident or close a case.

Sufficiency may consider:

- Critical question resolution
- Required evidence
- Unresolved information
- Contradictions
- Relevant relationships
- Scenario-specific investigation requirements

A sufficiency assessment will support decision-making but will not replace analyst judgment.

7.9 Analyst Review

The analyst will review:

- Associated alerts
- Association rationale
- Questions
- Evidence
- Entities and events
- Findings
- Contradictions
- Unresolved information
- Investigation history
- Sufficiency status

The analyst remains responsible for the final security decision.

8. Proposed System Architecture

The proposed architecture contains the following major components:

1. Security Telemetry Sources
2. Ingestion and Normalization
3. Alert-to-Case Association
4. Investigation Manager
5. Persistent Cyber Investigation State
6. Investigation Question Management

7. Evidence Acquisition
8. AI-Assisted Evidence Analysis and Reasoning
9. Sufficiency Assessment
10. Investigation Output
11. Analyst Review and Validation

A new alert starts a case when no related case is found; a related alert extends the existing case; an unrelated alert remains separate; and a later related alert can reactivate the case. State updates may reopen questions and trigger further evidence acquisition.

Alert A → no existing related case → new investigation

Alert B → related → existing investigation

Alert C → unrelated → separate investigation

Later related alert → existing investigation updated/reactivated

The precise implementation of individual internal algorithms may change during development, but these architectural responsibilities remain fixed.



Figure 1: Architecture Diagram

9. Tools and Technologies

Table 4: Tools and Technologies Used

Technology	Purpose
Wazuh	Central security monitoring and alert source
Sysmon and Suricata	Windows endpoint and network telemetry
Wazuh Indexer / OpenSearch	Search and retrieval of security events
Python with a REST backend	Core application and component integration
Streamlit	Analyst-facing case and timeline interface
PostgreSQL and Neo4j	Case records and investigation relationships

Technology	Purpose
Ollama with Qwen2.5-7B-Instruct	Local AI-assisted evidence interpretation
JSON/Filebeat feeds	Local telemetry ingestion
Local virtual machines	Controlled laboratory environment

Qwen2.5-7B-Instruct is the primary local model proposed for evaluation [30]. The team will test it on the available 24 GB RAM and 500 GB NVMe setup alongside telemetry and storage services. Model quantization or configuration changes may be considered if measurements show that the planned workload exceeds available resources. The proposal does not assume that performance or feasibility has already been demonstrated.

The association method and internal workflow may be refined during implementation, provided that the stated case-level behavior, analyst review, and evaluation measures are retained.

10. Evaluation Plan

The framework will be evaluated using controlled laboratory scenarios with predefined ground truth.

Evaluation will examine whether the prototype maintains appropriate case boundaries and whether its investigation state preserves usable, traceable context across each scenario.

10.1 Alert Association Evaluation

Table 5: Alert Association Evaluation Measures

Evaluation Measure	Purpose
Correct Association	Related alerts placed in their ground-truth case
Incorrect Merging	Unrelated alerts combined into one case
Missed Association	Related alerts left in separate cases
Case Separation	Independent activity remains in separate cases
Association Traceability	Analyst can inspect the recorded rationale

The exact association implementation will be evaluated experimentally rather than assumed to be correct.

Association results will be counted against the predefined alert-to-case labels. Correct associations, incorrect merges of unrelated activity, missed links between related alerts, and correctly separated cases will be reported by scenario. Investigation measures will be calculated from the number of required questions correctly resolved and required evidence items obtained; findings will be checked for direct support from the linked evidence. Completion time will be measured from receipt of the first scenario alert to the

point at which the system presents its investigation output for analyst review. AI outputs will also be checked for unsupported factual claims, inference latency, and peak memory use.

10.2 Scenario-Based Investigation Evaluation

Each scenario will be evaluated against ground truth defined before execution. The evaluation will examine case creation and extension, question status, evidence coverage, state updates, and whether the evidence supports the findings. The same scenario inputs and scoring rules will be used for every recorded run.

10.3 Investigation Evaluation Measures

Table 6: Investigation Evaluation Measures

Measure	Purpose
Investigation Completion Time	Time from first scenario alert to output for analyst review
Question Resolution	Required questions correctly resolved
Evidence Coverage	Required evidence items obtained
Evidence Reuse	Previously collected, still-valid evidence reused
Evidence-to-Finding Traceability	Findings linked to evidence that supports them
Investigation Completeness	Scenario requirements addressed in the case state
Sufficiency Assessment	Correctly identifies whether predefined requirements are met
State Updates and Reactivation	Records changes when new alerts or evidence arrive

10.4 AI Evaluation

AI-generated outputs will be evaluated independently from the association mechanism.

Table 7: AI Evaluation Measures

Measure	Purpose
Finding Correctness	Generated findings agree with scenario ground truth
Evidence Grounding	Factual claims are supported by linked evidence
Unsupported Claims	Claims without support are counted and reviewed
Question Resolution	AI assists with correctly answering scenario questions
Inference Latency	Time to generate AI-assisted output
Peak Memory Use	Memory consumed during the local model run

Every AI-generated investigation finding should be traceable to supporting evidence and remain subject to analyst validation.

10.5 Ground Truth

Ground truth will be defined before formal evaluation for each of the four scenarios.

Ground truth will define the expected relationships between alerts, relevant evidence, investigation questions, expected findings, and conditions that are sufficient or insufficient. Each student will independently check findings against the defined ground truth; disagreements will be documented and resolved jointly. Results will be reported by scenario and with counts alongside percentages because the test set is small.

11. Expected Outcomes

The project is expected to produce:

1. A functional persistent Cyber Investigation State Model
2. A bounded and explainable alert-to-case association mechanism
3. Multi-alert investigation case management
4. Question-driven evidence acquisition and evidence traceability
5. AI-assisted evidence analysis and investigation reasoning
6. Investigation sufficiency assessment
7. An analyst-facing dashboard and structured report
8. Experimental results from four controlled scenarios using the defined association, investigation, and AI measures

The intended outcome is a research prototype and evaluation report for a bounded laboratory use case, not a production-ready autonomous SOC platform.

12. Project Limitations and Constraints

The project will be subject to the following limitations:

Controlled laboratory environment: Evaluation will not reproduce full enterprise SOC scale, diversity, or operational noise.

Limited telemetry: The primary sources will be Wazuh, Sysmon, and Suricata.

Bounded association: The project will not attempt unrestricted enterprise-wide incident clustering.

Limited scenarios: Controlled scenarios cannot represent every type of real-world attack.

AI limitations: AI-generated reasoning may be incomplete, incorrect, or unsupported.

Evidence availability: Missing telemetry may prevent some questions from being resolved.

Resource constraints: Available hardware and academic time may limit model size, scenario scale, and experimental repetition.

Human oversight: Final conclusions remain subject to analyst validation.

No destructive response: Automated host isolation, file deletion, account disabling, or similar remediation is outside project scope.

List of Faculty Proposed Changes

SPINE: A Cyber Investigation State Model for AI-Assisted Cyber Incident Investigation in Security Operations Centers

Supervisor's Signature: _____

Proposed Change	Proposed By	Supervisor's Decision
Clarify Qwen2.5 selection, model size, integration approach, and practical resource requirements.	Faculty Member 1	Approved. Qwen2.5-7B-Instruct is selected as the primary local model; 24 GB RAM / 500 GB NVMe will be validated during implementation and quantization may be used if needed.
Add a scoring scheme to determine alert or threat level.	Faculty Member 1	Approved. Preserve the Wazuh rule level (0–16) and use the project priority bands: Low (1–5), Medium (6–11), High (12–14), Critical (15–16). Level 0 is excluded from actionable prioritization.
Strengthen the market survey through comparison with commercial and open-source systems such as Vectra AI and other SOC platforms.	Faculty Member 2	Approved. Compare relevant commercial and open-source systems and position the project as a focused research prototype for persistent investigation-state management.
Strengthen background study and use a hybrid alert-association approach	Faculty Member 2	Approved. Use contextual rules with an association method selected during implementation; keep decisions bounded, interpretable, and evaluable.
Define metrics for AI-model evaluation and explain how AI-generated investigation results will be justified.	Faculty Member 3	Approved. Evaluate finding correctness, evidence grounding, unsupported claims, latency, and peak memory; findings will reference evidence and require analyst validation.

Project Plan

Work Breakdown Structure: The WBS decomposes the proposed project into major deliverables and implementation activities covering research refinement, system design, laboratory setup, implementation, AI integration, testing, evaluation, and documentation.

Proposed WBS:

1. Project Management

- 1.1 Requirements, change control, meetings, and progress tracking

2. Research and Documentation

- 2.1 Literature and market survey
- 2.2 Requirements and technical background study
- 2.3 Proposal, final documentation, and user documentation

3. System Design and Core Framework

- 3.1 Architecture and Cyber Investigation State design
- 3.2 Telemetry ingestion and normalization
- 3.3 Hybrid alert-to-case association
- 3.4 Question-driven evidence acquisition and state updates

4. AI and Investigation Interface

- 4.1 Qwen2.5-7B-Instruct integration and resource testing
- 4.2 Evidence-analysis and reasoning agents
- 4.3 Analyst dashboard and structured investigation report

5. Testing and Evaluation

- 5.1 Scenario testing, ground-truth preparation, and alert-association evaluation
- 5.2 Four-scenario investigation evaluation
- 5.3 AI finding correctness, evidence grounding, unsupported-claim analysis, inference latency, and peak memory evaluation

6. Project Closure

- 6.1 Results analysis, final report, presentation, and documentation

Roles & Responsibility Matrix:

The listed durations are estimated person-days. Activities may overlap where dependencies allow, so their sum is not the total calendar duration. FYP-1 will focus on requirements, design, the local lab, case association, evidence acquisition, and a working prototype demonstrated with one scenario. FYP-2 will complete the four-scenario workflow, local AI integration, evaluation, and final documentation.

The matrix identifies the primary responsibilities of each team member for the project activities. Both students will review ground truth, evaluation results, and final findings.

WBS #	WBS Deliverable	Activity #	Activity to Complete the Deliverable	Duration (# of Days)	Responsible Team Member(s) & Role(s)
1.1	Project Management	1.1.1	Requirements coordination, meetings, progress tracking, and change control	8	Ahsan - Project Lead; Mubashir - Co-Lead
2.1	Research and Documentation	2.1.1	Literature, market survey, and technical background study	12	Ahsan - Research; Mubashir - Research Support
2.2	Research and Documentation	2.2.1	Requirements specification and evaluation-plan preparation	8	Ahsan - Requirements; Mubashir - Validation
2.3	Research and Documentation	2.3.1	Final proposal, results report, presentation, and user documentation	8	Ahsan + Mubashir - Joint
3.1	System Design and Core Framework	3.1.1	Cyber Investigation State and architecture design	10	Ahsan - Architecture/State; Mubashir - Integration
3.2	System Design and Core Framework	3.2.1	Telemetry pipeline, ingestion, and normalization for Wazuh, Sysmon, and Suricata	10	Mubashir - Lab/Telemetry; Ahsan - Integration
3.3	System Design and Core Framework	3.3.1	Hybrid alert-to-case association and recording of association rationale	10	Mubashir - Backend; Ahsan - State Integration
3.4	System Design and Core Framework	3.4.1	Question-driven evidence acquisition and investigation-state updates	12	Mubashir - Correlation; Ahsan - State/Logic

WBS #	WBS Deliverable	Activity #	Activity to Complete the Deliverable	Duration (# of Days)	Responsible Team Member(s) & Role(s)
4.1	AI and Investigation Interface	4.1.1	Qwen2.5-7B local integration, prompt design, and resource testing	10	Ahsan - AI/LLM; Mubashir - Environment Support
4.2	AI and Investigation Interface	4.2.1	Evidence-analysis and reasoning agents	10	Ahsan - Agents; Mubashir - Workflow Integration
4.3	AI and Investigation Interface	4.3.1	Analyst dashboard and structured investigation report	10	Mubashir - UI; Ahsan - Investigation Output
5.1	Testing and Evaluation	5.1.1	Scenario execution, ground truth, system testing, and bug fixing	12	Ahsan + Mubashir - Joint
5.2	Testing and Evaluation	5.2.1	Four-scenario investigation evaluation and analysis against predefined ground truth	8	Ahsan - Evaluation; Mubashir - Scenario Control
5.3	Testing and Evaluation	5.3.1	AI finding correctness, evidence grounding, unsupported-claim analysis, latency, and memory/resource evaluation	8	Ahsan - AI Evaluation; Mubashir - Metrics/Logging
6.1	Project Closure	6.1.1	Results analysis, final report, presentation, and user/end-user documentation	8	Ahsan + Mubashir - Joint

References

- [1] Wazuh, “Rules classification,” Wazuh documentation. [Online]. Available: <https://documentation.wazuh.com/current/user-manual/ruleset/rules/rules-classification.html>
- [2] Microsoft, “Sysmon,” Microsoft Learn. [Online]. Available: <https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon>
- [3] Open Information Security Foundation, “Suricata user guide,” Suricata documentation. [Online]. Available: <https://docs.suricata.io/en/latest/>
- [4] A. Sharma, J. Thakur, T. P. Sharma, R. Monie, and S. Shivam, “ALUSKORT: A hierarchical multi-agent cognitive architecture for autonomous security operations,” *Int. J. Appl. Math.*, vol. 38, no. 5s, pp. 488–509, 2025, doi: 10.12732/ijam.v38i5s.328.
- [5] B. Wei et al., “CORTEX: Collaborative LLM agents for high-stakes alert triage,” *arXiv:2510.00311*, 2025, doi: 10.48550/arXiv.2510.00311.
- [6] K. Kurniawan, R. F. Ardian, E. Kiesling, and A. Ekelhart, “AgCyRAG: An agentic knowledge graph based RAG framework for automated security analysis,” in *Proc. 2nd Int. Workshop on Retrieval-Augmented Generation Enabled by Knowledge Graphs (RAGE-KG)*, 2025, *CEUR Workshop Proc.*, vol. 4079, pp. 132–144. [Online]. Available: <https://ceur-ws.org/Vol-4079/paper11.pdf>
- [7] M. Landauer, F. Skopik, M. Wurzenberger, and A. Rauber, “Dealing with security alert flooding: Using machine learning for domain-independent alert aggregation,” *ACM Trans. Privacy Security*, vol. 25, no. 3, Art. no. 18, pp. 1–36, 2022, doi: 10.1145/3510581.
- [8] T. Ban, T. Takahashi, S. Ndichu, and D. Inoue, “Breaking alert fatigue: AI-assisted SIEM framework for effective incident response,” *Appl. Sci.*, vol. 13, no. 11, Art. no. 6610, 2023, doi: 10.3390/app13116610.
- [9] J. Bimbashi, “AutoFlow: Automatic support for alert sense-making,” M.S. thesis, Dept. Math. Comput. Sci., Eindhoven Univ. Technol., Eindhoven, The Netherlands, 2024. [Online]. Available: <https://research.tue.nl/en/studentTheses/autoflow>
- [10] Y. Jia, Y. Qi, H. Shang, R. Jiang, and A. Li, “A practical approach to constructing a knowledge graph for cybersecurity,” *Engineering*, vol. 4, no. 1, pp. 53–60, 2018, doi: 10.1016/j.eng.2018.01.004.
- [11] L. F. Sikos, “Cybersecurity knowledge graphs,” *Knowl. Inf. Syst.*, vol. 65, no. 9, pp. 3511–3531, 2023, doi: 10.1007/s10115-023-01860-3.
- [12] K. Kurniawan, A. Ekelhart, E. Kiesling, G. Quirchmayr, and A. M. Tjoa, “KRYSTAL: Knowledge graph-based framework for tactical attack discovery in audit data,” *Comput. Secur.*, vol. 121, Art. no. 102828, 2022, doi: 10.1016/j.cose.2022.102828.
- [13] P. Pirolli and S. K. Card, “The sensemaking process and leverage points for analyst technology as identified through cognitive task analysis,” in *Proc. Int. Conf. Intelligence Analysis*, McLean, VA, USA, 2005.
- [14] M. Vielberth, F. Böhm, I. Fichtinger, and G. Pernul, “Security operations center: A systematic study and open challenges,” *IEEE Access*, vol. 8, pp. 227756–227779, 2020, doi: 10.1109/ACCESS.2020.3045514.

- [15] T. Biege, M. Brockhoff, J. Kaspereit, F. Ising, L. Gröber, and S. Schinzel, “SoK: A taxonomy for cybersecurity incident response influence factors,” in Proc. 2026 IEEE 11th Eur. Symp. Security Privacy (EuroS&P), 2026, doi: 10.1109/EuroSP68448.2026.00068.
- [16] J. Tilbury and S. Flowerday, “Humans and automation: Augmenting security operation centers,” J. Cybersecurity Privacy, vol. 4, no. 3, pp. 388–409, 2024, doi: 10.3390/jcp4030020.
- [17] Vectra AI, “Vectra AI platform.” [Online]. Available: <https://www.vectra.ai/platform>
- [18] Security Onion Solutions, “Cases,” Security Onion documentation, ver. 2.4. [Online]. Available: <https://docs.securityonion.net/en/2.4/cases.html>
- [19] StrangeBee, “TheHive documentation.” [Online]. Available: <https://docs.strangebee.com/>
- [20] Splunk, “Splunk Enterprise Security.” [Online]. Available: https://www.splunk.com/en_us/products/enterprise-security.html
- [21] IBM, “IBM QRadar SIEM.” [Online]. Available: <https://www.ibm.com/products/qradar-siem>
- [22] Microsoft, “What is Microsoft Sentinel SIEM?,” Microsoft Learn. [Online]. Available: <https://learn.microsoft.com/en-us/azure/sentinel/overview>
- [23] Palo Alto Networks, “Cortex XSOAR.” [Online]. Available: <https://www.paloaltonetworks.com/cortex/cortex-xsoar>
- [24] Rapid7, “Incident Command.” [Online]. Available: <https://www.rapid7.com/products/siem/>
- [25] Fortinet, “FortiSIEM.” [Online]. Available: <https://www.fortinet.com/products/siem/fortisiem>
- [26] AiSOC contributors, “AiSOC,” GitHub repository. [Online]. Available: <https://github.com/beenuar/AiSOC>
- [27] Vigil contributors, “Vigil,” GitHub repository. [Online]. Available: <https://github.com/Vigil-SOC/vigil>.
- [28] OnyxLab, “AI-SOC documentation.” [Online]. Available: <https://research.onyxlab.ai/ai-soc/>
- [29] SOCfortress, “Talon,” GitHub repository. [Online]. Available: <https://github.com/taylorwalton/talon>
- [30] Qwen Team, “Qwen2.5-7B-Instruct model card,” Hugging Face. [Online]. Available: <https://huggingface.co/Qwen/Qwen2.5-7B-Instruct>

Approval

Project Supervisor

Comments _____

Name: _____

Date: _____ Signature: _____

Project Coordinator

Comments _____

Name: _____

Date: _____ Signature: _____